Fatlind Lici
15/03/2026

W12_D1
CSPT2025

Vulnerability Assessment

Traccia:

Effettuare un Vulnerability Assessment con Nessus sulla macchina **Metasploitable** indicando come target **solo** le **porte comuni** (potete scegliere come scansione il «basic network scan», o l'advanced e poi configurarlo)

A valle del completamento della scansione, **analizzate attentamente il report per ognuna delle vulnerabilità riportate, approfondendo qualora necessario con i link all'interno dei report e/o con contenuto da Web**.

Gli obiettivi dell'esercizio sono:

- **Fare pratica con lo strumento, con la configurazione e l'avvio delle scansioni**
- **Familiarizzare con alcune delle vulnerabilità note che troverete spesso sul vostro percorso da penetration tester**

Consegna:

- Report PDF per «tecnico»

Report tecnico è inteso come "quasi completo" che va ad indicare sia le porte che la vulnerabilità che la risoluzione, in modo da poter intervenire.

- Suggerimento: fare traduzione in italiano della descrizione e/o remediation

Facoltativo:

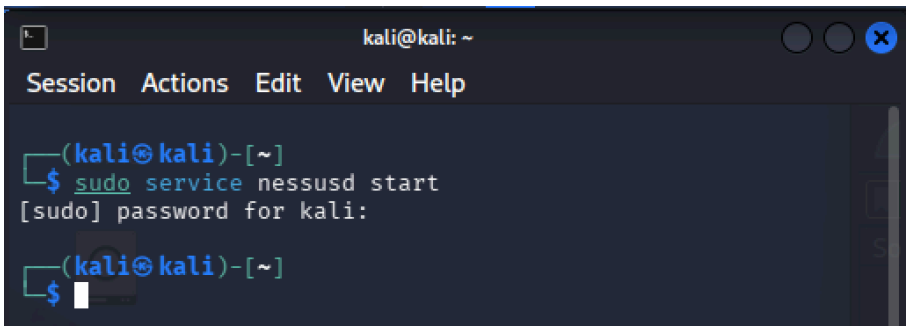
- Analisi/studio delle vulnerabilità (PDF) - servirà sia per exploit che remediation

- Report PDF per «dirigente»: Inteso come riassunto che va presentato ai dirigenti per l'approvazione a livello finanziario ecc. Non contiene troppi dettagli tecnici ma soltanto l'indicazione della vulnerabilità e soprattutto i grafici con la pericolosità delle varie vulnerabilità riscontrate

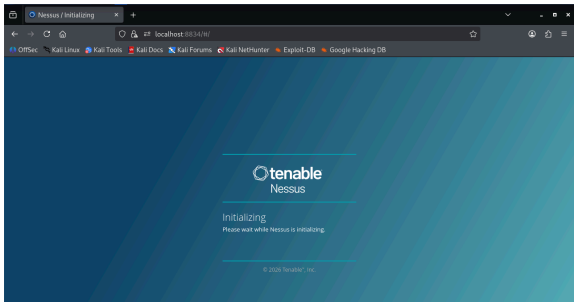
Macchine utilizzate:
- **Kali Linux** - Attaccante - 192.168.50.100
- **Metasploitable2** - Target - 192.168.50.101

Servizi utilizzati:
- Nessus

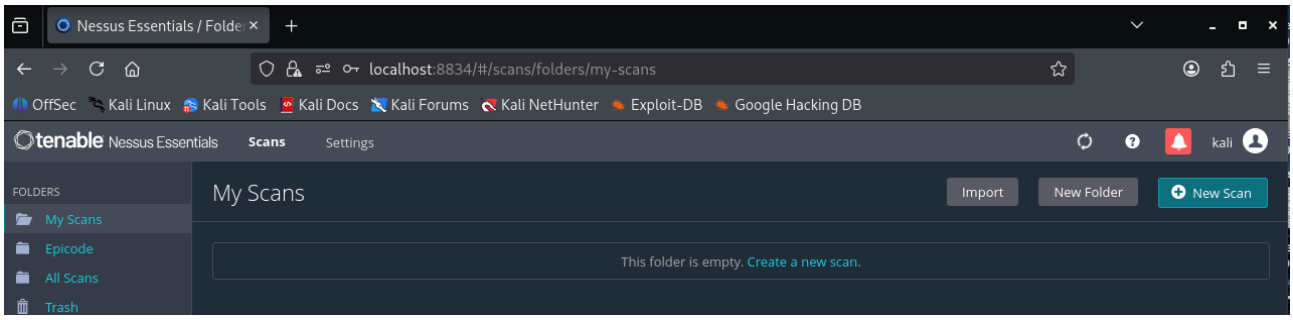
- Avviamo Nessus tramite terminale su kali:



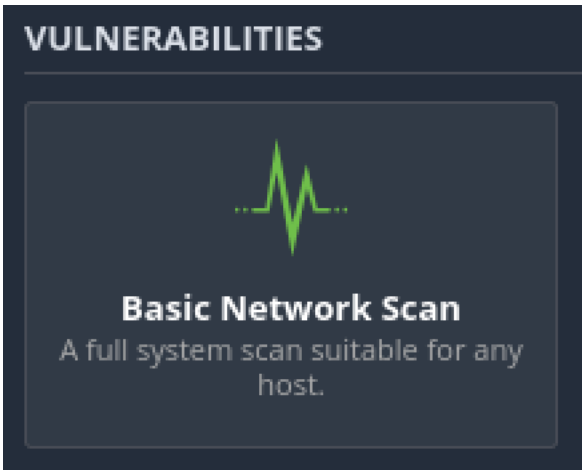
- Un volta avviato, apriamo il nostro motore di ricerca e cerchiamo l'indirizzo del server di Nessun: https://localhost:8834



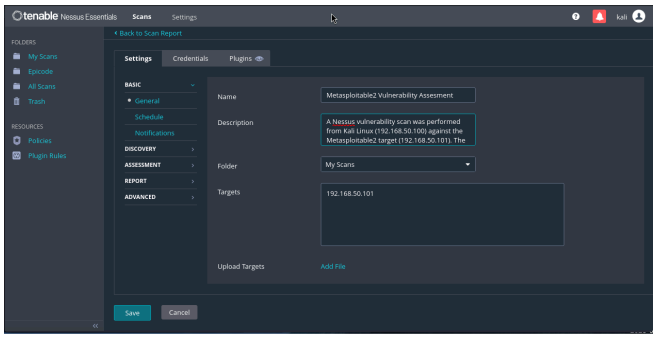
- Una volta effettuato l’accesso, entriamo nella dashboard di Nessus e andiamo su “New Scan”

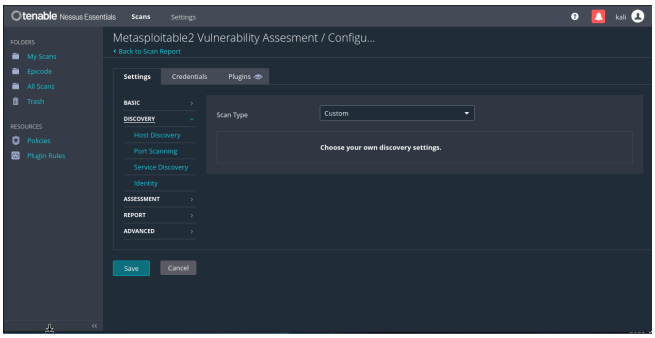


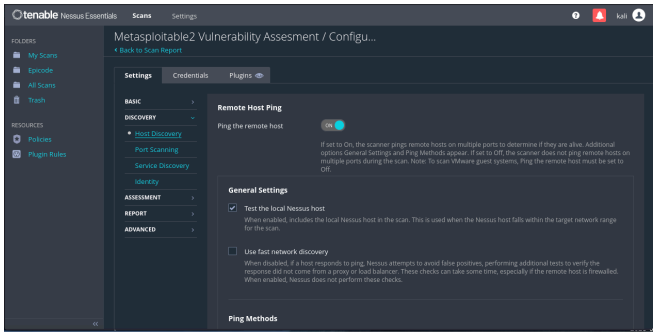
- Tool di servizio scegliamo:

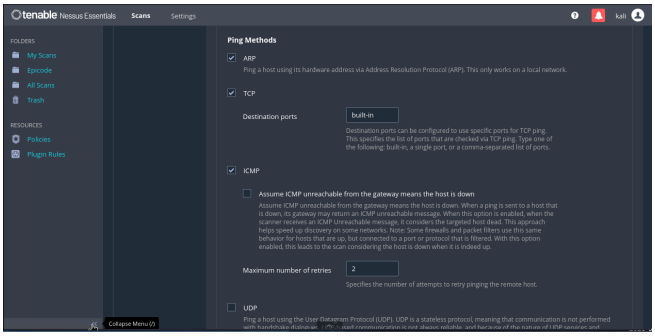


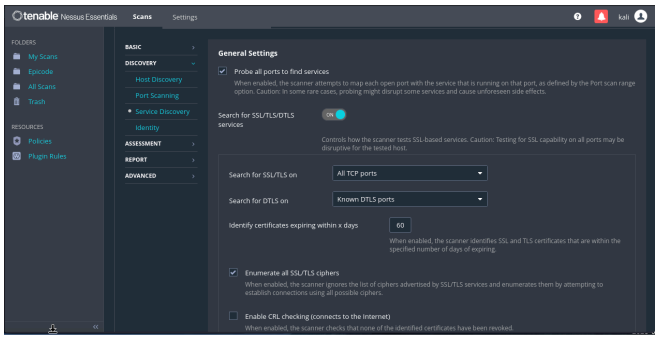
- A seguire la configurazione completa per effettuare la nostra scansione:

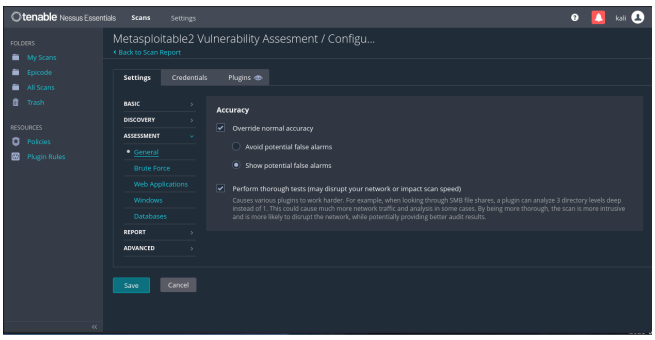


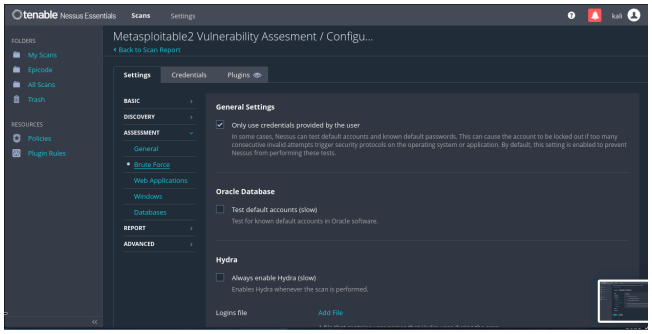


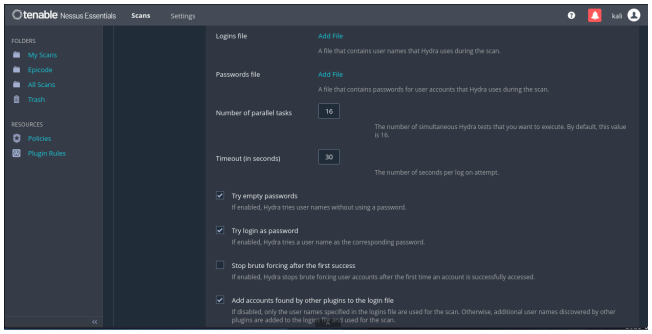


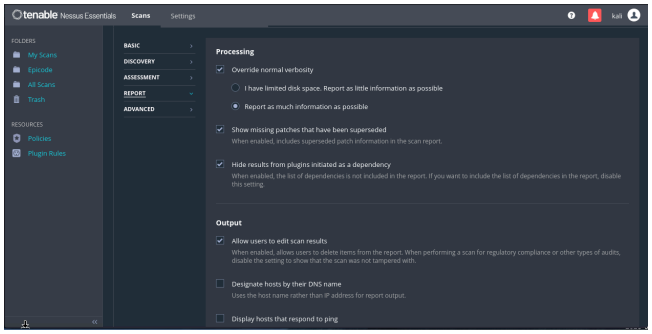


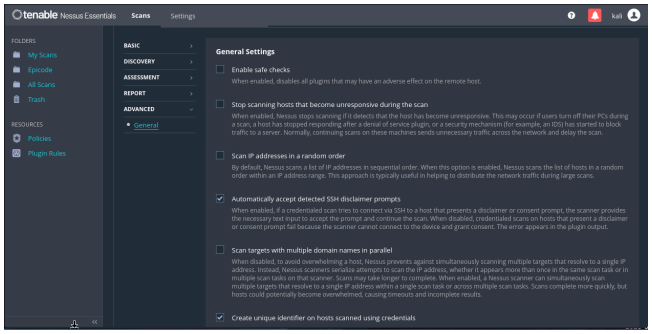




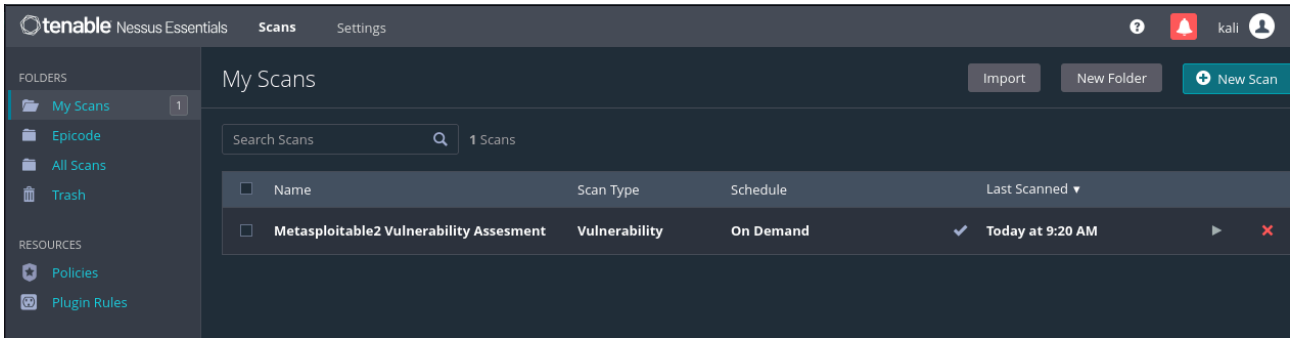






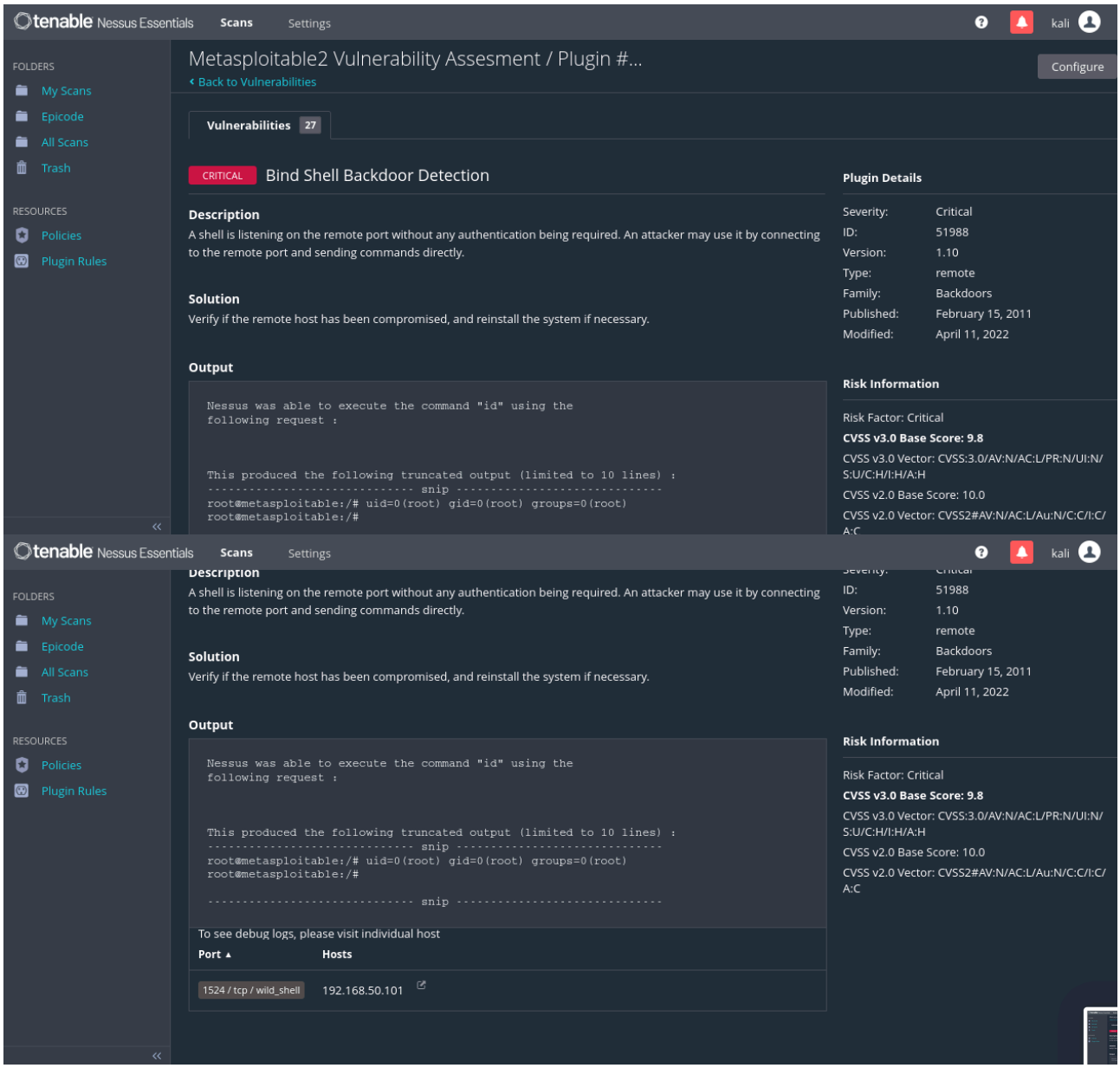


- Una volta eseguita la configurazione, salviamo la nostra nuova scansione ed avviamola con il tasto triangolare di Play.



- Selezionando lo stato della nostra scansione, compariranno i risultati con una palette di colori dove il rosso rappresenta una alta criticità assieme al numero CVSS racing dove il massimo della criticità è 10.

- A seguire una delle vulnerabilità critiche riscontrate:



Report breve versione tecnica:

Vulnerability Assessment Report

1. Introduction

A vulnerability assessment was performed using Nessus from Kali Linux (192.168.50.100) against Metasploitable (192.168.50.101). The scan focused on common ports to identify known vulnerabilities.

2. Scan Configuration

- **Scan Type:** Basic Network Scan
- **Target:** 192.168.50.101
- **Port Range:** Common Ports
- **Scan Type:** Unauthenticated

3. Identified Vulnerability

- Bind Shell Backdoor Detection
- **ID:** 51988
- **Port:** 1524/TCP
- **Severity:** Critical
- **CVSS v3.0 Base Score:** 9.8
- **Type:** Remote
- **Family:** Backdoors

4. Description

A bind shell backdoor was detected on port 1524. This service allows remote command execution without authentication, providing direct access to the system.

5. Impact

An attacker can gain full control of the system, execute commands, access sensitive data, and install malware.

6. Exploitation

An attacker can exploit this vulnerability by connecting to port 1524 using tools like Netcat. The service provides a remote shell without authentication, allowing execution of commands on the target system.

7. Remediation

Remove the backdoor, update the system, and restrict access using firewall rules.

8. Vulnerability Summary Table

Port	Service	Vulnerability	Severity
21	FTP	vsftpd Backdoor	Critical
23	Telnet	Weak Authentication	High
80	HTTP	Apache Outdated	Medium
445	SMB	Samba Badlock	Medium
1524	Bind Shell	Backdoor	Critical

9. Conclusion

The system is critically vulnerable due to the presence of a bind shell backdoor.

Versione report per l’esecutivo:

Executive Security Report

1. Executive Summary
A vulnerability assessment identified critical security issues in the Metasploitable system. The most severe finding is a bind shell backdoor that allows unauthorized remote access without authentication.

2. Key Finding
A critical bind shell backdoor was detected on the system, enabling attackers to remotely access and control the machine.

3. Risk Level
Critical.

4. Vulnerability Severity Distribution

Severity	Number of Vulnerabilities
Critical	2
High	1
Medium	2
Low	0

5. Business Impact
- **Financial Impact:** Exploitation may lead to financial losses due to system recovery, downtime, and potential regulatory penalties.
- **Reputational Impact:** A successful attack could damage the organization's reputation and reduce customer confidence.
- **Trust and Customer Confidence:** Security incidents may lead to loss of customer trust and potential customer churn.
- **Operational Impact:** System compromise could disrupt operations and lead to service interruptions.

6. Recommendations
It is recommended to immediately remove the backdoor, update the system, implement firewall protections, and perform regular security assessments.

7. Conclusion
The presence of critical vulnerabilities represents a serious risk to the organization. Immediate action is required to prevent potential compromise and protect business operations.